Networth Matrimony — Project Status Report

Report Date: October 14, 2026 | **Branch:** main (06f47d3) | **Repository:** D:\matrimony

Executive Summary

The platform is feature-complete on the backend. Phases 0–8 are delivered: authentication (with OTP delivery over MSG91), profile and discovery, payments and unlocks (including the section-15 pre-expiry reminder), trust and safety (including the report moderation queue), identity verification, notifications (with push delivery over Firebase), and the admin API with RBAC, audit logging, enrichment tooling, TOTP MFA, the section-30 moderation queue, and the Next.js admin dashboard. The remaining work is the Phase 9 mobile app. All gates are green with 824 automated tests passing.

Key Metrics

Metric	Value
Automated Tests	824 (559 API + 29 Admin + 236 Shared)
Test Suites	50 (35 API + 4 Admin + 11 Shared)
Admin Permission Keys	21
Current Commit	06f47d3
Status	All Gates Green

Implementation Status by Phase

Phase	Module	Status	Key Deliverables
0	Foundations	Complete	Schema, config, health, security, monorepo
1	Identity & Auth	Complete	OTP, JWT, rotating sessions, lockout
2	Profile & Master Data	Complete	CRUD, photos, master lists
3	Discovery	Complete	Two-way visibility, filters, pagination
4	Payments & Unlocks	Complete	Razorpay, webhooks, idempotency, expiry
5	Trust & Safety	Complete	Blocking, reporting, account deletion, report moderation queue
6	KYC/Verification	Complete	Contracts, service, controller, module
7	Notifications	Complete	Shared contracts, API module, list endpoint, unlock pre-expiry reminder, Firebase push delivery
8	Admin API	Complete	RBAC, audit, MFA, enrichment, moderation queue, Next.js dashboard
9	Mobile App	Planned	React Native

Recent Accomplishments

Unlock Pre-Expiry Reminder (Section 15 / C3)

- `UNLOCK_EXPIRY_REMINDER_HOURS` was configured but unused; a sweep now records one notification per unlock about two hours before it expires
- `ContactUnlock.reminderSentAt` marks a reminder sent and the claim is a conditional update, so a restart, redeploy or second instance cannot notify a buyer twice

- `UnlockExpiryReminder` follows the existing sweeper/`ClockDriftGuard` timer shape (5-minute interval, `unref`, boot sweep, failures logged not thrown)
- Channel is `PUSH`; the row also remains in the in-app list, which is not filtered by channel

Push Delivery over Firebase (Section 42, resolves GAP-12's push half)

- `PushGateway` seam with an `FcmPushGateway` on FCM HTTP v1: a service-account RS256 assertion is exchanged for a cached OAuth2 token, on `node:crypto` — no legacy server key and no `firebase-admin`; fails closed when unconfigured
- `DeviceToken` model + `DevicePlatform` enum and a `SENDING` claim status; migration `20261014140000_device_tokens_push`
- `POST/GET /devices` and `DELETE /devices/:token` under `JwtAuthGuard`; registration upserts on the token and reassigns its owner, and the token is never echoed back
- `PushDispatchService` claims a row `PENDING` → `SENDING` with a conditional update (at-least-once, never twice-per-worker), requeues a stale `SENDING` row, prunes a token FCM reports `UNREGISTERED`, and marks `SENT` / `FAILED`; `PushDispatchSweeper` runs on a 60-second timer
- A `PUSH` row for a member with no device stays `PENDING` and is delivered once one is registered

SMS OTP Delivery (MSG91, resolves GAP-12)

- `SmsGateway` seam (abstract class) with a `Msg91SmsGateway` on MSG91's Flow API, bound like the payment gateway so tests substitute it without the network; a small `SmsModule` keeps the module graph acyclic
- `AuthController.requestOtp` sends the code via MSG91 in production and fails closed (401) when MSG91 is unconfigured; outside production it still echoes `dev_code` so the flow stays testable without a provider account
- Flow API rather than MSG91's SendOTP API, because the platform owns OTP state (hashed, attempt-counted, expired, consumed at later steps); the code travels as a template variable and MSG91 only delivers it
- New config `SMS_TEMPLATE_ID` / `SMS_OTP_TEMPLATE_VAR` / `SMS_COUNTRY_CODE`; 9 gateway tests

Admin MFA (TOTP)

- Hand-rolled RFC 6238 TOTP and AES-256-GCM secret-at-rest encryption, no new dependency
- Opt-in self-service enrollment; the secret is persisted only after a matching code
- Login for an MFA-enabled admin returns a signed challenge; only the verify endpoint issues a session
- Wrong codes share the password lockout counter; disable requires a current code; audited `admin:manage` reset for lost devices

Report Moderation Queue (Section 30)

- `GET /admin/reports` (status filter + cursor pages), `GET /admin/reports/:id`, `POST /admin/reports/:id/review`, all behind `report:review`
- Resolution is terminal and pairs action with status; notes required to action
- SUSPEND suspends the reported account as its only side effect, guarded against reviving a DELETED account
- Every review writes a `report:review` audit row

AI Recommendations (Backend MVP)

- Curated interest tags with `GET/PUT /profile/interests`
- Feature-flagged For You feed (`GET /recommendations`) ranked by shared-interest overlap
- Reuses the existing discovery eligibility and two-way acceptance scope

Admin Dashboard (Next.js)

- `apps/admin` (`@matrimony/admin`): Next.js 16 App Router + React 19, talking only to the admin API
- Backend-for-frontend auth: the token pair lives only in httpOnly cookies; an edge proxy guards every route and refreshes the access token before it expires
- Password-then-TOTP login; session route handlers re-validate every API response with the shared Zod contracts
- Pages: overview, the moderation queue (status filter + detail review form), member list, administrator/role list
- Build pinned to webpack (the Next 16 Turbopack default panics writing this app's route chunks on Windows)

Quality Assurance

- Tests: 824 passed (559 API + 29 Admin + 236 Shared)

- Typecheck: PASS (workspaces + tools, including the seed)
- Lint: PASS
- Build: PASS (shared + API + admin)
- Full verification: PASS

Next Steps

- **Phase 9:** the React Native member app against the contracts in `packages/shared`
- Email provider is still open (the remaining half of GAP-12; SMS and push are resolved)